EWB COURSES

CYBERSECURITY ASSESSMENT 01

Security Foundations

Student name	Dhanshree D Gundlekar
Course	AI-Powered Cybersecurity
Assessment	Individual work | 100 marks

TASK A — SECURE A STUDENT ACCOUNT

A1. Five risks, assets and CIA impact

The CIA triad means confidentiality (keeping information private), integrity (keeping information accurate and unchanged) and availability (making sure systems and information can be accessed when needed). The following risks are based on Mira's situation in the assessment.

Risk	Asset at risk	CIA impact	Control	Limitation
1. Same short password is used for email and the learning portal.	Email, learning portal and personal/course information.	Confidentiality: if one password is discovered, both accounts may be accessed. Integrity and availability may also be affected if an attacker changes or locks the accounts.	Use a long, unique password for each account. A password manager can help create and store different passwords.	A password manager must itself be protected. A unique password does not prevent phishing or malware.
2. Mira approves unexpected sign-in prompts.	Learning portal account and its stored work.	Confidentiality: an unauthorised person may enter the account. Integrity: they may change submitted work or account details.	Deny unexpected prompts and report repeated requests to the college IT team. Use number-matching MFA if the portal supports it.	MFA is not perfect. A user can still approve a fraudulent prompt or be tricked by a convincing attack.
3. Device updates are postponed.	Laptop, files and accounts used on the laptop.	Confidentiality and integrity: attackers may exploit known software weaknesses. Availability: malware or system damage may stop the laptop working.	Install operating-system, browser and application security updates promptly, preferably with automatic updates enabled.	Updates can occasionally cause compatibility problems and do not protect against every new or unknown vulnerability.
4. The only project copy is stored on one laptop.	Project files and coursework.	Availability: device failure, theft or ransomware could make the only copy unavailable. Integrity may be affected if files are corrupted.	Keep regular backup copies in a secure cloud service or on an external drive, and test that files can be restored.	A connected backup may also be affected by ransomware. Cloud storage depends on account security and internet access.
5. A friend uses the laptop while Mira is signed in.	Mira's account, private files, browser sessions and coursework.	Confidentiality: the friend may see private information. Integrity: files or settings may be changed. Availability: files may be deleted.	Create a separate standard user account for the friend and lock Mira's screen whenever she leaves the laptop.	Separate accounts reduce accidental access but do not replace device encryption, strong account passwords or careful supervision.

A2. First three priority actions

1. **Secure the accounts first:** Mira should change the reused password to a unique, strong password, starting with email, and review account recovery details. Email is especially important because it may be used to reset other accounts. She should deny unexpected MFA prompts and report them. This comes first because someone may already be trying to access her accounts.

2. **Install pending security updates:** She should update the operating system, browser and other software. This reduces the chance that known weaknesses can be exploited. It is second because an unpatched device can put both accounts and files at risk.

3. **Protect and back up her work:** She should create a separate account for her friend, lock her own session and make a second backup of project files. This protects privacy and reduces the chance of losing coursework.

A3. Authentication versus authorisation

Authentication checks who a person is. For example, Mira enters her username and password and may confirm a multi-factor authentication prompt to prove that she is the account holder. **Authorisation** decides what an authenticated user is allowed to do. For example, the learning portal may allow Mira to view her own grades and submit assignments, while only a lecturer or administrator can edit grades or manage student accounts. Authentication happens before access permissions are applied.

TASK B — ANALYSE A SUSPICIOUS MESSAGE

B1. Five specific warning signs

The message contains several signs that should be checked carefully. These signs make the message suspicious, but the text alone does not prove who sent it or whether a website is malicious.

Evidence phrase	Why it needs scrutiny
“awards@campus-awards.example”	The college normally uses campus.example, but the sender uses a different domain. The sender address should be checked rather than trusted because it contains the word “campus”.
“Reply-To: help@personal-awards.example”	The reply address is different from the sender address and from the college’s normal domain. Replies could go to an unrelated address.
“FINAL WARNING” and “expires in 20 minutes”	Urgent language pressures the student to act quickly and discourages careful checking.
“enter your college password and OTP”	A request for both a password and a one-time password is highly risky. These are authentication secrets and should not be shared through an email link.
“Do not contact the college office” and “photo of your identity card”	The message discourages independent verification and asks for sensitive identity information. A student should contact the college through a known official channel instead.

B2. Safe verification process

1. Do not click the link, reply to the message or open its attachment. Do not provide a password, OTP or identity-card image. 2. Open the college website by typing its known official address yourself, or use a saved official bookmark. 3. Sign in through the normal student portal and check whether a scholarship notice is present. 4. Contact the scholarship or IT office using a phone number or email address obtained independently from the official college website or student handbook. 5. Report the message to the college’s IT/security team and follow its instructions.

HTTPS only means that the connection to a website is encrypted and that the browser has established a connection to the domain shown. It does not prove that the domain belongs to the college or that the page is honest. A familiar display name can also be chosen by a sender, so the full sender and reply-to addresses must be checked.

B3. If a student has already entered a password and OTP

1. **Act quickly:** From a trusted device, open the genuine college portal using its known address. Do not use the message link again. 2. **Protect the account:** Change the affected password to a new, unique one. If the same password was reused elsewhere, change it on those accounts too. 3. **End suspicious access:** Ask the official IT team to revoke active sessions or tokens, review sign-in activity and reset MFA methods if needed. 4. **Report:** Contact the college IT/security team through an independently verified channel and provide the suspicious message and approximate time of the incident. Do not send passwords or OTPs. 5. **Follow up:** Check recovery email/phone details, forwarding rules, recent account changes and other unusual activity. Watch for further suspicious messages.

B4. What cannot be established from the message alone

The message alone cannot establish the real identity or location of the sender, or prove that the linked website was accessed or used to steal information. Additional evidence could include full email headers, authentication results, mail-server logs and a security review of the domain and website by authorised staff. The supplied addresses are fictional training examples, so they should not be visited.

TASK C — TRIAGE A SIGN-IN ALERT

C1. Four-point timeline: observed events and interpretation

Time (IST)	Observed evidence	Interpretation (not proven fact)
09:00–09:01	student07 had a successful password event from 192.0.2.10, followed by an approved MFA event. The lab notes identify this as the usual classroom egress IP.	This appears consistent with the normal classroom sign-in pattern.
10:14–10:16	Two password attempts from 198.51.100.23 failed. A password attempt from the same IP then succeeded.	Someone or something entered a password successfully after two failures. The log does not identify the person or explain how the password was obtained.
10:17–10:18	An MFA request was denied and the next MFA request was approved. The student says they approved a prompt at about 10:18 because they thought it would stop repeated requests.	The approval may have allowed a sign-in the student did not intend. The student's statement is important context, but the logs alone do not show who initiated each prompt.
10:20	A session was created from the same source IP. The student says they did not sign in after 09:05.	The session may be unauthorised. The timing and user's statement make this a high-priority account security concern.

C2. Likely explanation, alternative explanation and checks

Likely explanation: An unauthorised person may have obtained or guessed the student's password and attempted to sign in. After the password succeeded, repeated MFA prompts were sent. The student approved one prompt by mistake, which may have allowed the session to be created. This pattern can be consistent with an MFA-prompt fatigue attack, but the available evidence does not prove the attacker's identity or method.

Alternative explanation: The sign-in may have involved a legitimate but unfamiliar network, such as a VPN, proxy or different internet connection, and the student may have unintentionally approved the sign-in. This is less consistent with the student's statement that they did not intend to sign in, but it should still be checked rather than ruled out.

Two useful checks: (1) Review identity-provider records for device, browser, user-agent, session details, MFA method and exact prompt activity; compare them with the student's usual devices and sign-ins. (2) Ask the authorised network/IT team to check VPN, proxy and network logs and compare the source IP and timing with known college network activity. An IP address alone does not identify a person.

C3. Three prioritised actions for the authorised IT team

1. **Preserve evidence:** Export and securely retain relevant authentication, MFA, session and network logs, including timestamps and time-zone information. Record who collected the evidence and when. Do not delete or overwrite the logs.

2. **Contain the account risk:** Contact the student through a trusted channel, revoke active sessions/tokens, temporarily block sign-in if necessary under college procedure, and require a password reset from a trusted device. Review and reset MFA registration if compromise is suspected.

3. **Investigate and monitor:** Review account changes, recovery details, mailbox or portal activity and other sign-ins. Check whether other accounts show similar activity. Restore normal access only after the account is secured and the incident has been assessed.

C4. Incident summary (60–100 words)

On 18 October 2026, student07 had a normal-looking sign-in from the usual classroom IP at 09:00–09:01. At 10:14–10:16, two password attempts failed and a later attempt from a different documentation IP succeeded. MFA was denied and then approved at 10:18, after which a session was created at 10:20. The student says they did not intend to sign in and approved a prompt to stop repeated requests. Unauthorised access is possible but not proven. Preserve logs, revoke sessions and secure the account.

TASK D — REVIEW AN AI SECURITY ANSWER

D1. Five unsafe or unsupported claims/actions and corrections

AI statement	Correction and reason
"The email is safe because it uses HTTPS."	Incorrect. HTTPS encrypts the connection to a domain; it does not prove that the domain is genuine or trustworthy. The sender/reply-to mismatch, urgency and request for credentials still require scrutiny.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported. The logs show events associated with a documentation IP address, not the identity of a person or how the password was obtained. An IP address may be shared, routed or masked.
"MFA prevents every account compromise."	Incorrect. MFA adds a layer of protection but can be defeated or misused through prompt fatigue, phishing, stolen sessions or other attacks. Unexpected prompts should be denied and reported.
"Delete the suspicious logs."	Unsafe. Logs are important evidence for understanding what happened. They should be preserved securely and handled by authorised IT staff, not deleted.
"Send the student's password to support so they can test it."	Unsafe. Passwords must remain secret and should never be sent to support staff. Support should use approved account recovery and verification procedures without asking for the password or OTP.

D2. Better prompt for an AI tool

"Analyse only the fictional email evidence and synthetic sign-in log provided below. Identify the facts directly shown in the evidence and separate them from possible explanations or assumptions. Do not identify or guess the real-world person behind an IP address. Do not claim that a website or sender is malicious unless the evidence supports that conclusion. Explain uncertainty and list what additional authorised evidence would help. Recommend safe account-protection and reporting steps. Do not ask for, repeat or expose any password, OTP, identity document or other secret. If the evidence is insufficient, clearly say what cannot be established."

D3. Corrected security advice (100–150 words)

The scholarship message should be treated as suspicious because its sender and reply-to addresses do not match the college's normal domain, it creates time pressure, and it asks for a password, OTP and identity-card photo. Do not click its link or reply. Verify the notice by opening the college portal independently or contacting the college through an official contact method. In the sign-in log, the successful password event, MFA approval and new session are concerning, especially because the student says the approval was accidental. However, the IP address does not identify a person or prove how the password was obtained. The IT team should preserve logs, revoke suspicious sessions, secure the account and investigate further.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: AI assistance was used to help organise and draft explanations for this assessment. The responses are based on the fictional scenarios in the assessment brief. I will review the content, check that I understand it, make any necessary corrections and submit work that I can explain in my own words.

Evidence note 1 — CISA: CISA's Secure Our World guidance provides basic advice on using strong passwords, enabling multi-factor authentication, recognising phishing and installing software updates. These topics support the account-security controls and phishing response discussed in Tasks A and B.

Reference: Cybersecurity and Infrastructure Security Agency (CISA), *Secure Our World*. https://www.cisa.gov/secure-our-world

Evidence note 2 — NIST: NIST's Generative AI Profile discusses risks such as confabulation and the need to evaluate and verify AI-generated information. This supports checking the AI answer against the supplied evidence instead of accepting confident statements without proof.

Reference: National Institute of Standards and Technology (NIST), *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST AI 600-1. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf